

Unsafe Dynamic Script Generation / Potential XSS

Assessment Identifier: **WS-STA-09** | Assessment Type: **Static** | Date: **September 08, 2026**

Severity: MEDIUM	CVSS: 6.1	CWE: CWE-79
OWASP: A03	WASC ID: N/A	Confidence: Medium candidate
Target / Component: scripts/profile-news-hybrid-clustering-7782-browser.mjs; scripts/build-use-cases.mjs	Affected URL: https://github.com/worldmonitor/worldmonitor/blob/main/scripts/build-use-cases.mjs	Parameter: bundle and pageUrl dynamic script concatenation

1. Description

Static analysis identified dynamically generated script/HTML content involving values such as bundle and pageUrl. This becomes a vulnerability if attacker-controlled data reaches an executable script context.

2. Steps to Reproduce

1. Identify the dynamically inserted value.
2. Trace its source.
3. Determine whether it can be attacker-controlled.
4. Run script generation locally.
5. Inspect the generated HTML/script.

3. Controlled Proof of Concept

Safe Proof of Concept:
 Use a harmless local marker such as XSS-TEST and inspect whether it is inserted into an executable context without safe serialization or encoding.

4. Business & Security Impact

If attacker-controlled data reaches executable script context, malicious JavaScript could potentially execute in users' browsers.

5. Remediation Recommendations

Primary Fix: Avoid concatenating untrusted input into JavaScript, use safe serialization, validate generated URLs, avoid dynamic script generation where possible, and use CSP as defense in depth.

1. Use JSON.stringify() or safe serialization functions rather than raw string interpolation for inline variables.
2. Validate that pageUrl matches approved protocols (https:) and domain allowlists.
3. Prefer static bundling workflows over runtime dynamic script emission.

6. Evidence & Validation

Evidence Type: Textual / Static Source Analysis
 This finding was identified through static analysis of repository source code and configuration files. Per assessment requirements, no simulated runtime screenshots or dynamic PoC captures are applicable. Verification must be performed via source code review and static analysis tool verification.

Authorization & Safety Compliance: *This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.*